1 Censorship (& Privacy)

1.1 Einführung in Internetzensur

Internetzensur beschränkt, welche Informationen im Internet veröffentlicht oder abgerufen werden können. Sie wird von Regierungen und Organisationen eingesetzt.

Ziele der Zensur

- **Schutz von Rechten:** Blockierung urheberrechtlich geschützter Inhalte.
- **Sicherheit:** Schutz vor schädlichen oder sensiblen Inhalten (z. B. Malware, illegale Pornografie).
- **Politische Kontrolle:** Einsatz als Propagandamethode zur Förderung spezifischer religiöser oder politischer Agenden.

Die Umsetzung erfolgt in vier Hauptkategorien:

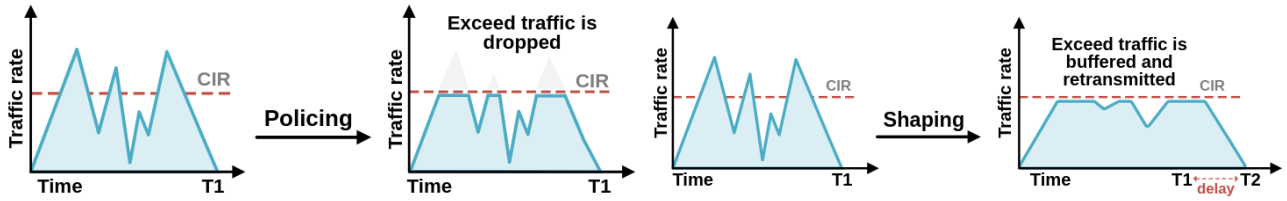
1. **Drosselung (Throttling):** Verlangsamung des Datenverkehrs.
2. **Blockierung:** Verhindern des Zugriffs auf spezifische Verbindungen.
3. **Entfernung:** Löschung von Inhalten.
4. **Abschaltung:** Vollständige Abschaltung des Internets.

1.2 Drosselung des Datenverkehrs (Throttling)

Die Drosselung reduziert die dem Netzwerkverkehr zugewiesene Bandbreite. Sie ist diskreter als eine vollständige Blockierung und oft schwerer als absichtliche Zensur zu erkennen, da sie zufällig oder absichtlich wirken kann. Sie kann geografisch oder App-basiert gezielt eingesetzt werden.

Es gibt zwei technische Hauptmethoden zur Durchsetzung von Ratenlimits:

- **Traffic Shaping**: Verzögert Pakete, die das zugewiesene Ratenlimit überschreiten.
- **Traffic Policing**: Verwirft Pakete (dropped), die das Ratenlimit überschreiten.



1.3 Blockierung von Verbindungen

1.3.1 Domain-Entfernung

Behörden können Nameserver dazu zwingen, Domains aus ihren Verzeichnissen zu entfernen.

1.3.2 DNS-Manipulation

- **DNS Injection (via Man-on-the-Side):** Zielt auf das DNS-Protokoll ab. Der Zensor fängt DNS-Anfragen für verbotene Domains ab und schleust eigene Antworten (mit falschen IP-Adressen) ein.
- **DNS Filtering:** Der DNS-Nameserver selbst steht unter der Kontrolle des Zensors. Es ist kein Abfangen und Injizieren erforderlich, da der Server direkt die falsche IP-Adresse liefert.

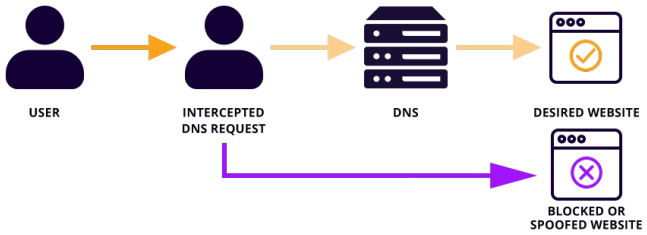


Figure 1: *Injection*

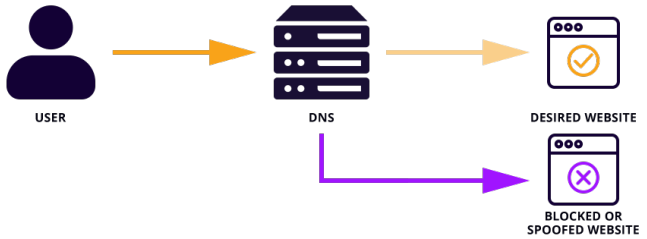


Figure 2: *Filtering*

1.3.3 Man-on-the-Side (MotS) für HTTP

Ablauf eines MotS-Angriffs

1. Der Client initiiert eine legitime HTTP-Anfrage.
2. Der Zensor (hat Zugriff auf den Kanal, kann aber Pakete nicht ändern/löschen) fängt die Verbindung ab und injiziert ein TCP-Segment, um den Client umzuleiten.
3. Dieses injizierte Paket erreicht den Client vor der legitimen Antwort des Webservers, welche daraufhin verworfen wird.
4. Der Client landet auf einem bösartigen Webserver.

1.3.4 BGP Hijacking

Behörden leiten den Internetverkehr für bestimmte Ziel-Präfixe oder autonome Systeme um oder blockieren ihn. **Beispiel:** Pakistan versuchte 2008 YouTube durch eine "False Origin Announcement" (falsche Präfix-Ankündigung) zu blockieren, was den globalen Traffic umlenkte.

1.3.5 IP-Blocking

Behörden weisen Internetanbieter (ISPs) an, den Zugriff auf bestimmte IP-Adressen zu blockieren. Dies kann auch auf dem Endgerät oder durch einen MotS-Angreifer geschehen.

1.4 Entfernung von Inhalten

Inhalte können auf Anfrage von Regierungsbehörden (Gerichte, Exekutive, Polizei) aus dem Internet entfernt werden. Häufige Gründe umfassen nationale Sicherheit, Urheberrecht, Verleumdung und Privatsphäre.

1.5 Zensur-Werkzeuge und Technologien

1.5.1 Deep Packet Inspection (DPI)

Deep Packet Inspection (DPI)

DPI ist im Datenpfad ("on-path") positioniert. Es hat vollen Zugriff auf Paket-Header, nutzt Quell-/Zielports sowie IP-Adressen und kann den Paket-Payload analysieren. Es sucht nach Mustern, Fingerabdrücken und verbotenen Schlüsselwörtern.

DPI und Verschlüsselung: DPI kann verschlüsselte Payloads nicht ohne die richtigen Schlüssel entschlüsseln. Durch KI und ML kann DPI jedoch:

- Verkehrsverbindungen über Metadaten und Handshake-Muster analysieren.
- Netzwerkfluss-Statistiken auswerten (z. B. Erkennung von Botnetzen).
- Verschleierungstechniken wie Tor oder VPN erkennen.
- Fingerprinting (z. B. JA4/JA4+) für SSL/TLS-Verbindungen nutzen.

Nachteile: Rechenintensiv, zeitaufwendig und abhängig von vortrainierten KI/ML-Modellen (unzuverlässig bei unbekannten Angriffen).

1.5.2 Zwangsfilterung

Kann auf Infrastrukturebene (ISP, DNS, BGP) geschehen oder durch zwangsweise installierte Software auf Endgeräten. Regularien in der EU umfassen die Urheberrechtsrichtlinie (Art. 17) und den Digital Services Act (DSA).

1.6 Fallstudie: China

1.6.1 Great Firewall of China (GFW)

Befindet sich im Datenpfad zwischen China und dem globalen Internet. Untersucht den Inhalt ausgehender Pakete.

- Bei erkannten illegalen Inhalten in TCP-Verbindungen wird ein **RST-Paket** gesendet (Verbindungsabbruch).
- Nutzt IP-Blocking und DPI-Heuristiken zur Analyse verschlüsselten Verkehrs.

1.6.2 Great Cannon (GC)

Ein In-Path-System mit vollständigen MitM-Fähigkeiten (Man-in-the-Middle).

- Es bewaffnet den Datenverkehr unbeteiligter externer Nutzer, die chinesische Websites besuchen.
- Injiziert bösartigen Code (JavaScript), um DDoS-Angriffe gegen Zensur-Kritiker (z. B. GitHub) zu starten.

1.7 Privacy: Grundlagen

Privacy

Laut NIST: Die Zusicherung, dass die Vertraulichkeit von und der Zugang zu bestimmten Informationen über eine Entität geschützt ist. Anwendungsbereiche umfassen Networking (z. B. VPN, Tor), Datenbanken (Federated Learning) und Kryptographie.

1.8 Networking: The Onion Routing (TOR)

TOR bietet stark gegen Überwachung und Verkehrsflussanalyse geschützte, anonyme Verbindungen.

Funktionsweise des Onion Routing Protokolls

1. Der Tor-Client bezieht eine Liste von Knoten (Nodes) von einem Directory Server.
2. Der Client wählt einen zufälligen Pfad durch das Netzwerk. Der Verkehr wird über einen **Entry Guard**, ein **Middle Relay** und ein **Exit Relay** geleitet.
3. Pakete werden mehrlagig (wie eine Zwiebel) mit den Schlüsseln der Knoten verschlüsselt. Jeder Knoten entschlüsselt eine Schicht.

Wissensverteilung im Pfad:

- **Entry Guard:** Kennt die IP des Nutzers, aber nicht den Zielserver.
- **Middle Relay:** Kennt nur Entry und Exit Relay (weder Nutzer noch Ziel).
- **Exit Relay:** Kennt den Zielserver (Web Server) und entschlüsselt die letzte Schicht (kann Daten lesen, falls kein HTTPS genutzt wird), kennt aber den Nutzer nicht.

Tor-Bridges: Wenn öffentliche Entry Guards blockiert sind, können Nutzer **Bridges** (nicht öffentlich gelistete IP-Adressen) verwenden. Diese werden über alternative Kanäle wie Telegram verteilt und in nicht überschneidenden Buckets mit Ratenbegrenzung vergeben.

1.8.1 TOR Services (Hidden Services)

Ermöglichen es, Websites (.onion-Adressen) anonym anzubieten. Weder Inhalt noch Identität/Standort des Servers sind sichtbar.

- **Intro Points:** Der Hidden Server verbindet sich über Tor-Relays mit sogenannten **Intro Points**. Eine signierte Liste dieser Intro Points wird im Directory veröffentlicht.
- **.onion-Adresse:** Die Adresse enthält (seit Version 3) den vollständig Base32-enkodierten öffentlichen Schlüssel des Servers, eine Versionsnummer und eine Checksumme. Die Checksumme schützt vor Tippfehlern.
- **Verbindungsaufbau:** Der Client bestimmt einen **Rendezvous Point** und teilt diesem ein Einmal-Geheimnis (Secret String) mit. Der Client sendet diese Infos über die Intro Points an den Service. Der Service verbindet sich mit dem Rendezvous Point und sendet den Secret String. Bei Übereinstimmung sind beide Parteien doppelt anonym über Tor verbunden.

Anonymitätsgrenzen in TOR: TOR bietet keine perfekte Anonymität.

- **Website Fingerprinting:** Ein lokaler Angreifer (z. B. lokaler ISP) analysiert Verkehrsmuster, um die besuchte Website zu erraten.
- **Sybill/Eclipse Angriff:** Wenn ein Angreifer eine große Menge von Eingangs- und Ausgangsknoten kontrolliert, können Datenströme korreliert werden.
- **Self-Deanonymization:** Nutzer deanonymisieren sich selbst durch Metadaten (Browserversion) oder ihr Verhalten.

1.9 Datenschutz in Datenbanken: Federated Learning

Das Zentralisieren großer Datenmengen (z. B. Gesundheitsdaten) verstößt oft gegen Datenschutzgesetze. Lokales Training von Machine Learning (ML) Modellen ist jedoch problematisch, da kleine Datensätze verzerrt sind und Modelle schlecht generalisieren.

Federated Learning

Ein dezentrales ML-Framework. Clients (z. B. Krankenhäuser) trainieren Modelle auf ihren **lokalen Daten**. Es werden **nur die Modellgewichte** (Updates) an einen zentralen Server gesendet. Der Server aggregiert diese zu einem globalen Modell. Die Rohdaten verlassen nie die lokale Umgebung.

Sicherheitsprobleme: Modellupdates können sensible Informationen preisgeben. Ein Insider (z. B. ein ehrlicher, aber neugieriger Client) kann in sequenziellen Trainingszyklen **Membership-Inference Angriffe** durchführen, um festzustellen, ob bestimmte Datenpunkte Teil des Trainingsdatensatzes einer anderen Partei waren.

Gegenmaßnahme - Differential Privacy (DP):

- Begrenzt mathematisch den Einfluss einzelner Personen auf das Endergebnis, indem **Rauschen** hinzugefügt wird.
- *Data Suppression:* Löscht bestimmte Eigenschaften (schützt Personen, die im Datensatz sind).
- *Data Perturbation:* Fügt Rauschen hinzu oder ersetzt Werte (schützt sowohl Personen im Datensatz als auch außerhalb).

1.10 Kryptographie: Homomorphe Verschlüsselung

Homomorphic Encryption

Ermöglicht es, Berechnungen **direkt auf verschlüsselten Daten (Chiffretext)** durchzuführen, ohne sie vorher zu entschlüsseln. Das Ergebnis der Berechnung entspricht nach dem Entschlüsseln dem Ergebnis, das bei einer Berechnung auf Klartextdaten entstanden wäre.

Arten der homomorphen Verschlüsselung:

- **Full homomorphic Encryption (FHE):** Unterstützt unbegrenzte Additions- und Multiplikationsoperationen. Erlaubt beliebige Berechnungen, ist aber derzeit extrem ressourcenintensiv.
- **Somewhat homomorphic Encryption (SHE):** Unterstützt Addition und Multiplikation nur für eine begrenzte Anzahl von Operationen. Ist schneller, wird aber durch die Akkumulation von Rauschen im Chiffretext limitiert.
- **Partially homomorphic Encryption (PHE):** Unterstützt unbegrenzt **nur eine** Art von Operation (entweder Addition oder Multiplikation).